Jio Platforms Limited

Security & Compliance Report

Consent Management System

COPYRIGHT INFORMATION
No part of this document may be copied, reproduced, stored in any retrieval system, or transmitted in any form or by any means, either electronically, mechanically, or otherwise, without prior written permission.

© Copyright Jio Platforms Limited.
All rights reserved.
Jio Platforms Limited, Reliance Corporate Park
Thane Belapur Road, Ghansoli-400 701

TRADEMARKS
All the brand names and other products or services mentioned in this document are identified by the trademarks or service marks of their respective owners

DISCLAIMER
The information in this document is subject to change without notice and should not be construed as a commitment by Jio Platforms Limited. assumes no responsibility or makes no warranties for any errors that may appear in this document and disclaims any implied warranty of merchantability or fitness for a particular purpose

Date: November 26, 2025 *Released document | Version 1.0*

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

Version History

Date	Contributor	initial Draft	Ver	State
Nov 20 2025	Mayur Jalora	Created the document	0.1	Draft
Nov 26, 2026	Lokesh Sharma	Released Document	1.0	Released

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

Table of Contents

Version History *1*

Table of Contents *2*

1. Executive Summary *3*

2. System Security Architecture Overview *4*

3. Cryptography & Encryption Standards *5*

3.1 Key Management 5
3.2 Encryption Standards 5
3.3 Digital Signing 5

4. Immutability Architecture *6*

4.1 Canonicalization 6
4.2 Hash Chain Structure 6
4.3 Append-Only Database 6

5. Secure Consent Lifecycle (End-to-End) *8*

6. Audit Trail Architecture *9*

6.1 Logging Model 9
6.2 6.2 WORM Storage 9
6.3 6.3 Verification APIs 9

7. DPDP Compliance Mapping *10*

8. Security & Operational Controls *11*

9. Compliance Evaluation & Comparison *12*

9.1 Compliance Matrix 12
9.2 Comparison With Global Benchmarks 13
9.3 Internal Security Comparison (Before → After CMS) 13

10. Conclusion *14*

11. Overall Compliance Summary *15*

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

1. Executive Summary

This report provides a comprehensive overview of the security, cryptographic, immutability, and DPDP-compliance controls implemented within the Consent Management System (CMS). It includes system-wide architecture, cryptographic standards, audit trail mechanisms, and a compliance comparison against industry benchmarks.

The CMS implements enterprise-grade security with RSA-4096 signing, AES-256-GCM encryption, immutable hash-chained storage, strong RBAC governance, and tenant-isolated key management through HashiCorp Vault. All consent records are persisted in an append-only, tamper-evident data model, ensuring legal defensibility and Section 65B readiness.

The overall assessment confirms that the system is highly secure, technically compliant, and production-ready, with the only improvement area being the establishment of a documented automated testing suite.

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

2. System Security Architecture Overview

The CMS architecture is built on four foundational pillars:

1) **Cryptographic Assurance:**
   a. RSA-4096 signing
   b. AES-256-GCM encryption
   c. Vault-managed keys with strict RBAC

2) **Immutable Storage:**
   a. Append-only (WORM-like) inserts
   b. Chain hashing for tamper detection
   c. Deterministic canonical payload processing

3) **Auditability:**
   a. Immutable WORM logs
   b. SIEM forwarders (Kafka, ELK, Splunk)
   c. Verification APIs for recomputing hashes and signatures

4) **DPDP Compliance:**
   a. Purpose-bound consent
   b. Retention management
   c. Identity verification
   d. Transparent audit verification
   e. Plaintext consent payloads are never stored. All sensitive data exists only in encrypted or hashed form.

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

3. Cryptography & Encryption Standards

3.1 Key Management

- Each tenant receives a dedicated RSA-4096 keypair stored securely in HashiCorp Vault.
- Vault returns vaultRef and keyVersion for audit traceability.
- Access to keys is controlled strictly through service-account-based RBAC.

3.2 Encryption Standards

- AES-256-GCM96 is used to encrypt canonical JSON payloads.
- Stored values include only encryptedRef, never plaintext.
- Vault-issued encryption tokens are mandatory for all operations.

3.3 Digital Signing

- Consent artifacts are signed using RSA-4096.
- Output is a signed JWT/JWS containing metadata: *iat*, *keyVersion*, *consentId*.
- Ensures integrity, non-repudiation, and traceability.

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

4. Immutability Architecture

4.1 Canonicalization

Deterministic canonical formatting ensures stable signatures and hashes:

- Sorted keys
- ISO-8601 timestamps
- Standardized handling of arrays and nulls
- Removal of volatile/transient fields

4.2 Hash Chain Structure

- `payloadHash = SHA256(canonicalString)`
- `currentHash = SHA256(previousHash + '|' + payloadHash)`

This creates an unbroken tamper-proof chain across the consent lifecycle.

4.3 Append-Only Database

- No update/delete operations permitted
- Insert-only WORM behavior
- Ensures legal-grade immutability

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

5. Secure Consent Lifecycle (End-to-End)

1) **Key Onboarding** – RSA-4096 keypair generated and stored in Vault
2) **Consent Intake** – Field validation, OAuth2 authentication, identity checks
3) **Canonicalization** – Generate deterministic canonical payload
4) **Signing** – Vault signs canonicalString/hash → returns *signedJwtRef*
5) **Encryption** – AES-256-GCM encryption → *encryptedRef*
6) **Hash Computation** – SHA-256 payload hash + chain hash
7) **Persist Consent** – Append-only save with hashes, encryptedRef, metadata
8) **Response** – { consentId, currentHash, signedJwtRef }
9) **Verification & Audit** – Public-key signature validation & chain hash recomputation

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

6. Audit Trail Architecture

6.1 Logging Model

- Centralized audit microservice
- Captures user actions, IPs, timestamps, correlation IDs

6.2 6.2 WORM Storage

- Immutable logs
- Integrations available for SIEM platforms (Kafka, ELK, Splunk)

6.3 6.3 Verification APIs

- Signature validation
- Full audit recomputation and chain validation

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

7. DPDP Compliance Mapping

DPDP Principle	CMS Implementation
Lawful Purpose	Purpose attached to each consent
Notice & Consent	Stored bilingual/multilingual notice block
Storage Limitation	Auto-archive & retention workflows
Integrity & Security	RSA-4096, AES-256-GCM, immutable chain
Transparency	Audit & verification APIs
Accountability	Full chain-of-custody traceability

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

8. Security & Operational Controls

1) OAuth2 + DF identity enforcement
2) Vault RBAC for encryption and signing operations
3) Atomic persistence after all crypto operations
4) TLS 1.3 for transport security
5) Optional field-level PII encryption
6) Chain-hash tamper detection
7) Multi-tenant isolation

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

9. Compliance Evaluation & Comparison

9.1 Compliance Matrix

All 19 checks are preserved below in polished form.

#	Parameter	Summary	Status	Remarks
1	Immutable consent metadata	Append-only model (Insert/Get only)	Yes	Strong immutability
2	Cryptographic proof	RSA-4096 signed canonical payload	Yes	Strong non-repudiation
3	Real-time validation	API-level validations + auth	Yes	Secure transactions
4	Modular architecture	Separate modules for crypto, hashing, persistence	Yes	Maintainable
5	Audit logs	payloadHash, previousHash, vaultRef, timestamps	Yes	Full traceability
6	Scalability	Stateless APIs + append-only DB	Yes	Highly scalable
7	Encryption at rest	Vault-managed AES-256 encryption	Yes	Strong confidentiality
8	Hashing	SHA-256 chain hashing	Yes	Tamper detection
9	Tamper-proof audit chain	previousHash + currentHash	Yes	Cryptographic integrity
10	RBAC	Strict Vault & API-level access	Yes	Strong governance
11	Deployment readiness	Fully integrated with Vault and DB	Yes	Production-ready
12	Testing & automation	Deterministic canonicalization	⚙	Requires full test suite
13	Audit verification	Supports full recomputation	Yes	Independent verification
14	Key management	Vault lifecycle management	Yes	Enterprise standard
15	Canonical JSON	Deterministic formatting	Yes	Prevents signature mismatches
16	Atomic persistence	Only after crypto operations succeed	Yes	Consistent transactions
17	Traceability	Hash chain + metadata	Yes	Total lineage
18	No Update/Delete	Strict append-only	Yes	Reinforced immutability
19	Section 65B	Strong cryptographic artefacts	Yes	Requires formal affidavit

"CONFIDENTIAL – FOR NeGD/(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

9.2 Comparison With Global Benchmarks

Category	CMS	Industry Tools	Verdict
Encryption	AES-256-GCM, RSA-4096	AES-256, RSA-2048/4096	Stronger
Immutability	Hash chain + append-only	Audit logs only	Superior
Signing	Mandatory RSA-4096	Optional	More robust
Canonical payload storage	Never stored (encryptedRef only)	Often stored encrypted	Better confidentiality
Verification	Hash recompute + signature validate	Limited	More transparent
DPDP alignment	Purpose-linked	GDPR-first	Better India fit

9.3 Internal Security Comparison (Before → After CMS)

Area	Before CMS	After CMS
Consent integrity	Editable	Tamper-proof chain
Key handling	App-controlled	Vault-managed
Logging	Basic logs	Immutable WORM logs
Compliance	Partial	Fully DPDP-aligned
Verification	Manual	Automated cryptographic validation

"CONFIDENTIAL – FOR NeGD (MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

10. Conclusion

The Consent Management System delivers a best-in-class implementation of cryptographic integrity, immutability, DPDP compliance, and audit reliability.
With RSA-4096 signing, AES-256-GCM encryption, Vault-managed keys, and a chain-hashed append-only storage model, the system ensures strong privacy guarantees, tamper-proof records, and legal defensibility under Section 65B.

Overall System Rating:

- ⇒ Highly Secure
- ⇒ Technically Compliant

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"This document is submitted only for Code for Consent Challenge, organised by NeGD (a part of MeitY) and shall not be used for any other purpose."

11. Overall Compliance Summary

Category	Status
Security & Cryptography	Fully Compliant
Data Immutability & Auditability	Fully Compliant
System Architecture & Scalability	Fully Compliant
Access Control & Governance	Fully Compliant

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"

"CONFIDENTIAL – FOR NeGDv(MeitY) USE ONLY"